Jr.Pen 7.5. IDOR

Task 1 - What is an IDOR?

IDOR stands for Insecure Direct Object Reference and is a type of access control vulnerability. This type of vulnerability can occur when a web server receives user-supplied input to retrieve objects (files, data, documents), too much trust has been placed on the input data, and it is not validated on the server-side to confirm the requested object belongs to the user requesting it.

Task 2 - An IDOR Example

Imagine you've just signed up for an online service, and you want to change your profile information. The link you click on goes to http://online-service.thm/profile?user_id=1305, and you can see your information.

Task 3 - Finding IDORs in Encoded IDs

Encoded IDs: Encoding ensures that the receiving web server will be able to understand the contents. Encoding changes binary data into an ASCII string commonly using the `a-z, A-Z, 0-9 and =` character for padding. The most common encoding technique on the web is base64 encoding and can usually be pretty easy to spot. You can use websites like https://www.base64decode.org/(opens in new tab) to decode the string, then edit the data and re-encode it again using https://www.base64encode.org/(opens in new tab) and then resubmit the web request to see if there is a change in the response.

> What is a common type of encoding used by websites? Base64

Task 4 - Finding IDORs in Hashed IDs

Hashed IDs: Hashed IDs are a little bit more complicated to deal with than encoded ones, but they may follow a predictable pattern, such as being the hashed version of the integer value. For example, the Id number 123 would become 202cb962ac59075b964b07152d234b70 if md5 hashing were in use. It's worthwhile putting any discovered hashes through a web service such as https://crackstation.net/(opens in new tab) (which has a database of billions of hash to value results) to see if we can find any matches.

Task 5 - Finding IDORs in Unpredictable IDs

Unpredictable IDs: If the Id cannot be detected using the above methods, an excellent method of IDOR detection is to create two accounts and swap the Id numbers between them. If you can view the other users' content using their Id number while still being logged in with a different account (or not logged in at all), you've found a valid IDOR vulnerability.

Task 6 - Where are IDORs located

The vulnerable endpoint you're targeting may not always be something you see in the address bar. It could be content your browser loads in via an AJAX request or something that you find referenced in a JavaScript file.

Task 7 - A Practical IDOR Example

We'll start by investigating how this information gets pre-filled. If you open your browser developer tools, select the network tab and then refresh the page, you'll see a call to an endpoint with the path /api/v1/customer?id=`{user_id}`. This page returns in JSON format your user id, username and email address. We can see from the path that the user information shown is taken from the query string's id parameter (see below image).

